

# Incident Response Report

NetSupport Manager RAT Command & Control Activity  
Compromised Endpoint DESKTOP-TEYQ2NR in the EASYAS123 Domain

|                       |                                                                                                                                                   |
|-----------------------|---------------------------------------------------------------------------------------------------------------------------------------------------|
| Incident date         | 28 February 2026 (C2 activity observed 19:56 UTC on 28 Feb)                                                                                       |
| Report date / version | 5 October 2026                                                                                                                                    |
| Prepared by           | Firas, SOC Analyst (Home SOC Lab)                                                                                                                 |
| Evidence sources      | Packet capture 2026-02-28-traffic-analysis-exercise.pcap (Malware-Traffic-Analysis.net); Suricata eve.json and fast.log from the offline replay   |
| Incident category     | Malicious code: Remote Access Trojan (RAT) with active Command & Control (C2)                                                                     |
| Severity              | CRITICAL                                                                                                                                          |
| Status                | Analysis complete. Detection rule validated; prevention controls authored; containment, eradication and recovery actions recommended (Section 5). |

## Contents

|                                                     |    |
|-----------------------------------------------------|----|
| 1. Executive Summary.....                           | 2  |
| 2. Incident Timeline & Key Metrics .....            | 3  |
| 3. Asset & Identity Scoping .....                   | 3  |
| 4. Technical Analysis & Evidence Verification ..... | 5  |
| 5. Containment, Eradication & Remediation .....     | 8  |
| 6. Appendix .....                                   | 10 |

# 1. Executive Summary

*Written for non-technical management.*

## 1.1 Incident Overview

On 28 February 2026, analysis of captured network traffic confirmed that an internal workstation, **DESKTOP-TEYQ2NR (10.2.28.88)**, in the **EASYAS123** Active Directory domain was compromised and was under the control of a remote attacker. Seconds after looking up the domain **vadusa[.]xyz**, the machine opened a connection to the Command & Control (C2) server **45.131.214[.]85** and kept it open for **4 hours 20 minutes**, checking in every 60 seconds (261 check-ins, 264 requests in total). The traffic uses the protocol of **NetSupport Manager**, a legitimate remote-administration product that criminals frequently abuse as a Remote Access Trojan (RAT). The server answered, which shows a live two-way control channel; it was still open when the capture ended.

## 1.2 Risk / Impact Level

### CRITICAL

A RAT gives the attacker complete remote-desktop control of the workstation: viewing the screen, running commands, moving files and harvesting data and credentials. The infected host is domain-joined and the user account **brolf** authenticated to the domain controller, so the foothold can be used to attempt **lateral movement across Active Directory**. After the first exchanges the channel is encrypted, so what the attacker did on the machine cannot be read from the network capture.

**Observations that limit the visible impact.** The channel behaved like an idle heartbeat: about 93 KB in both directions over four hours, every check-in the same size, and the host talked only to its domain controller. No bulk data transfer, interactive remote-control session or lateral movement is visible in the capture. This fits an implant waiting for tasking, but the content is encrypted, so it cannot be proven, and the rating stays CRITICAL while the channel is open.

## 1.3 Current Status

| Workstream             | Status      | Detail                                                                                                                                                       |
|------------------------|-------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Detection & analysis   | Complete    | Victim, user, C2 domain/IP, session profile and threat-intel context established and cross-validated across several tools.                                   |
| Detection engineering  | Validated   | Suricata rule <b>SID 1000001</b> alerted on 264 of 264 C2 HTTP transactions.                                                                                 |
| Active prevention      | Authored    | IPS <b>drop</b> rules <b>SID 1000003</b> , <b>SID 1000004</b> , <b>SID 1000005</b> , <b>SID 1000006</b> and a PowerShell host-firewall block script written. |
| Containment            | Recommended | Actions defined in Section 5.1; they have not been executed in this exercise.                                                                                |
| Eradication & recovery | Pending     | Disk forensics and re-image required (Sections 5.2 and 5.3).                                                                                                 |

## 1.4 Decisions Requested from Management

- **Authorise immediate network isolation** of DESKTOP-TEYQ2NR and a forced credential reset for user **brolf**.
- **Approve blocking** of 45.131.214[.]85 (firewall, proxy) and of the domain vadusa[.]xyz (DNS) across the estate.
- **Approve a full re-image** of the workstation rather than clean-up in place, and a sweep of other endpoints and DNS logs for the same indicators.
- **Approve a staged rollout** of the IPS drop rule: alert-only first, then enforcement.

### 1.5 Scope and Confidence

Confidence that the host is running NetSupport RAT C2 is **high**: protocol content, behaviour, server banner, DNS resolution and threat-intelligence reputation all agree. The evidence is network-only; the points that remain open (initial infection vector, attacker actions) are listed in Section 4.6.

## 2. Incident Timeline & Key Metrics

|                                                    |                                                |                                                |                                                        |                                                        |
|----------------------------------------------------|------------------------------------------------|------------------------------------------------|--------------------------------------------------------|--------------------------------------------------------|
| <b>60 s</b><br>Beacon interval<br>(jitter < 0.3 s) | <b>4h 20m</b><br>One persistent<br>TCP session | <b>264</b><br>C2 HTTP requests<br>(264 alerts) | <b>≈ 93 KB</b><br>Total C2 traffic,<br>both directions | <b>8</b><br>Vendors flagging<br>the C2 IP (VirusTotal) |
|----------------------------------------------------|------------------------------------------------|------------------------------------------------|--------------------------------------------------------|--------------------------------------------------------|

Figures come from the Suricata flow record: 78,539 bytes to the server, 17,020 bytes to the client, 15,637 seconds.

### 2.1 Incident Lifecycle

| Date / Time (UTC)        | Event stage                          | Details                                                                                                                                                                                |
|--------------------------|--------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 2026-02-28 19:55:08      | Capture start / baseline             | Earliest activity of 10.2.28.88: a DNS SRV lookup for a domain controller sent to 10.2.28.2.                                                                                           |
| 19:55:50.9 to 19:55:51.1 | Preceding web activity               | The host resolves and opens a TLS connection to <code>www.fmcsa.dot.gov</code> about 0.3 s before the first C2 lookup. Temporal correlation only; relevance unknown (Section 4.6).     |
| 19:55:51.250 to .371     | C2 domain resolved                   | DNS query for <code>vadusa[.]xyz</code> sent to 10.2.28.2; answer A record <code>45.131.214[.]85</code> , TTL 300.                                                                     |
| 19:55:51.373             | C2 connection established            | TCP session <code>10.2.28.88:51912 → 45.131.214[.]85:443</code> starts. It carries plain-text HTTP, not TLS, and never closes.                                                         |
| 19:55:51.680 and .887    | Initial detection: session set-up    | First POST ( <code>CMD=POLL</code> , 22 bytes) and a 244-byte encrypted exchange. SID 1000001 fires on the first request.                                                              |
| 19:55:52.239 onward      | Active RAT beaoning                  | Automated 60-second heartbeat with User-Agent <code>NetSupport Manager/1.3</code> : 261 beacons, the last at 00:16:28.527. Request bodies 76 and 77 bytes, then exactly 36 bytes each. |
| 2026-03-01 00:16:28.733  | Session still open at capture end    | Flow state <i>established</i> , closed only by capture shutdown; 264 HTTP transactions in total.                                                                                       |
| Analysis phase           | Detection and prevention engineering | SID 1000001 validated against the capture; drop rule SID 1000003 and host-firewall script authored and validated.                                                                      |

All times are UTC: Suricata `eve.json` timestamps (+01:00) minus one hour, cross-checked with `fast.log`. HTTP records in `eve.json` are written at flow timeout and share an unreliable timestamp, so alert and flow times were used. The 264th alert appears last in `fast.log` with an out-of-order time (20:55:06 local); it is a flow-timeout artifact of the same session.

## 3. Asset & Identity Scoping

The IP address alone is not a reliable identity because addresses change. The host was therefore tied to a physical device, a system name and a user identity, and each value was cross-checked in a second tool.

| Asset parameter          | Value             | Source and method                                                                                   |
|--------------------------|-------------------|-----------------------------------------------------------------------------------------------------|
| Host system              | DESKTOP-TEYQ2NR   | NetBIOS Name Service (NBNS) registration                                                            |
| IP address               | 10.2.28.88        | Wireshark: Statistics > Endpoints > IPv4; DHCP ACK from 10.2.28.1 in Suricata <code>eve.json</code> |
| MAC address              | 00:19:d1:b2:4d:ad | Layer 2 Ethernet headers; matches the DHCP client MAC                                               |
| Impacted domain          | EASYAS123         | Kerberos AS-REQ <code>realm</code> field                                                            |
| Compromised user account | brolf             | Kerberos AS-REQ <code>cname-string</code> field                                                     |

| Asset parameter         | Value     | Source and method                                                    |
|-------------------------|-----------|----------------------------------------------------------------------|
| Domain controller / DNS | 10.2.28.2 | Kerberos, LDAP, SMB and DNS peer; it also answered the C2 DNS lookup |

**Verification.** NetworkMiner independently parsed the same capture and confirmed the IP address, the operating-system fingerprint, the computer name and the Active Directory account.

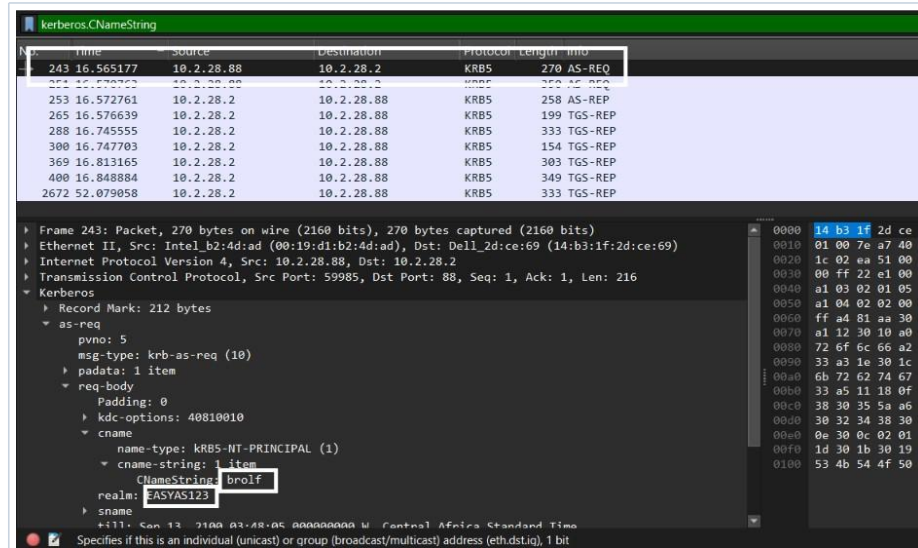


Figure 1. Wireshark filter `kerberos.CNameString: AS-REQ` from 10.2.28.88 to the domain controller exposing user `brolf` and realm `EASYAS123`.

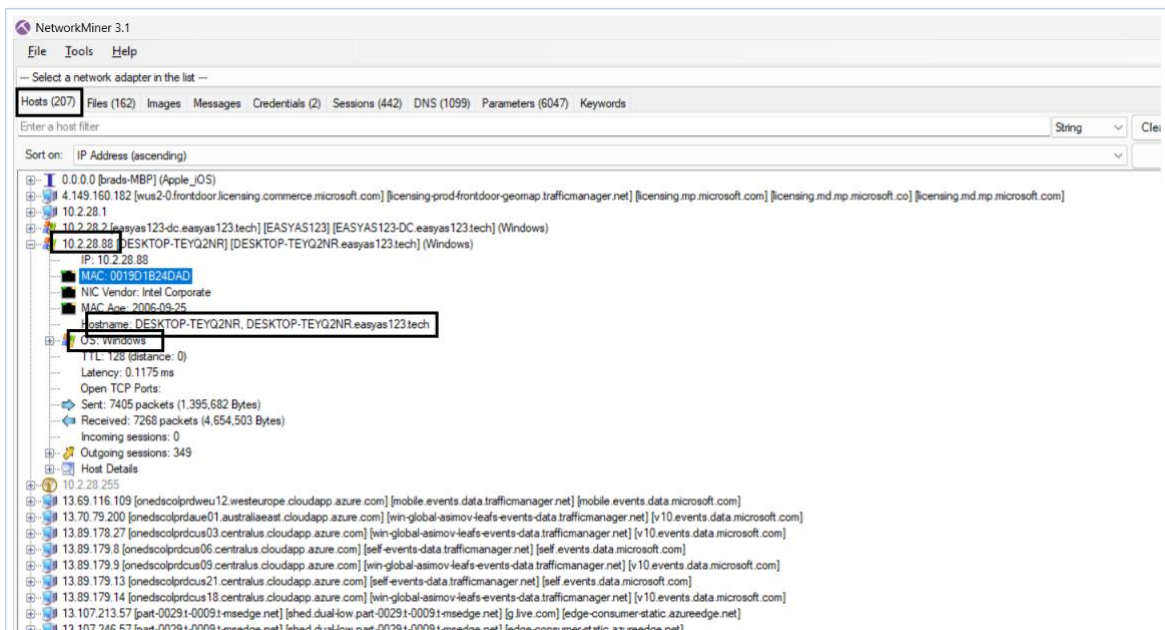


Figure 2. NetworkMiner cross-validation of host identity (Hosts and Credentials tabs).

### 3.1 Lateral Movement Check

The Suricata flow records show that 10.2.28.88 exchanged internal traffic only with the domain controller 10.2.28.2 (DNS 53, LDAP 389, Kerberos 88, SMB 445, DCE/RPC 135 and dynamic ports, NTP 123), the DHCP server 10.2.28.1 and the subnet broadcast address (NetBIOS). No SMB, RDP or other connection to a peer workstation appears, and there is no scanning pattern. **No lateral movement is visible in this capture;** the account and host must still be treated as exposed (Section 5.1).

## 4. Technical Analysis & Evidence Verification

### 4.1 C2 Channel Profile

|                     |                                                                                                                                                                                       |
|---------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| C2 domain           | vadusa[.]xyz: A record 4 5 . 1 3 1 . 2 1 4 [.] 8 5 , TTL 300, resolved through 10.2.28.2 at 19:55:51.371 UTC, 2 ms before the TCP session began                                       |
| C2 server           | 45.131.214[.]85                                                                                                                                                                       |
| Hosting provider    | MHost LLC (hosting provider, AbuseIPDB)                                                                                                                                               |
| Geolocation         | Netherlands (VirusTotal) and Germany (AbuseIPDB). The sources disagree, which is common for hosting-provider address space; the provider, not the country, is the reliable attribute. |
| Protocol and port   | Plain-text HTTP/1.1 over TCP port 443 (no TLS handshake)                                                                                                                              |
| Session             | One persistent keep-alive connection from source port 51912; 276 packets to the server, 274 to the client                                                                             |
| HTTP method and URI | POST to /fakeurl[.]htm; Host header is the raw IP                                                                                                                                     |
| Request User-Agent  | NetSupport Manager/1.3                                                                                                                                                                |
| Content-Type        | application/x-www-form-urlencoded                                                                                                                                                     |
| Server banner       | NetSupport Gateway/1.92 (Windows NT) with HTTP 200 OK                                                                                                                                 |
| Payload behaviour   | Plaintext check-in (CMD=POLL, INFO=1, ACK=1), then encrypted session data (CMD=ENC D, ES=1, DATA=...)                                                                                 |

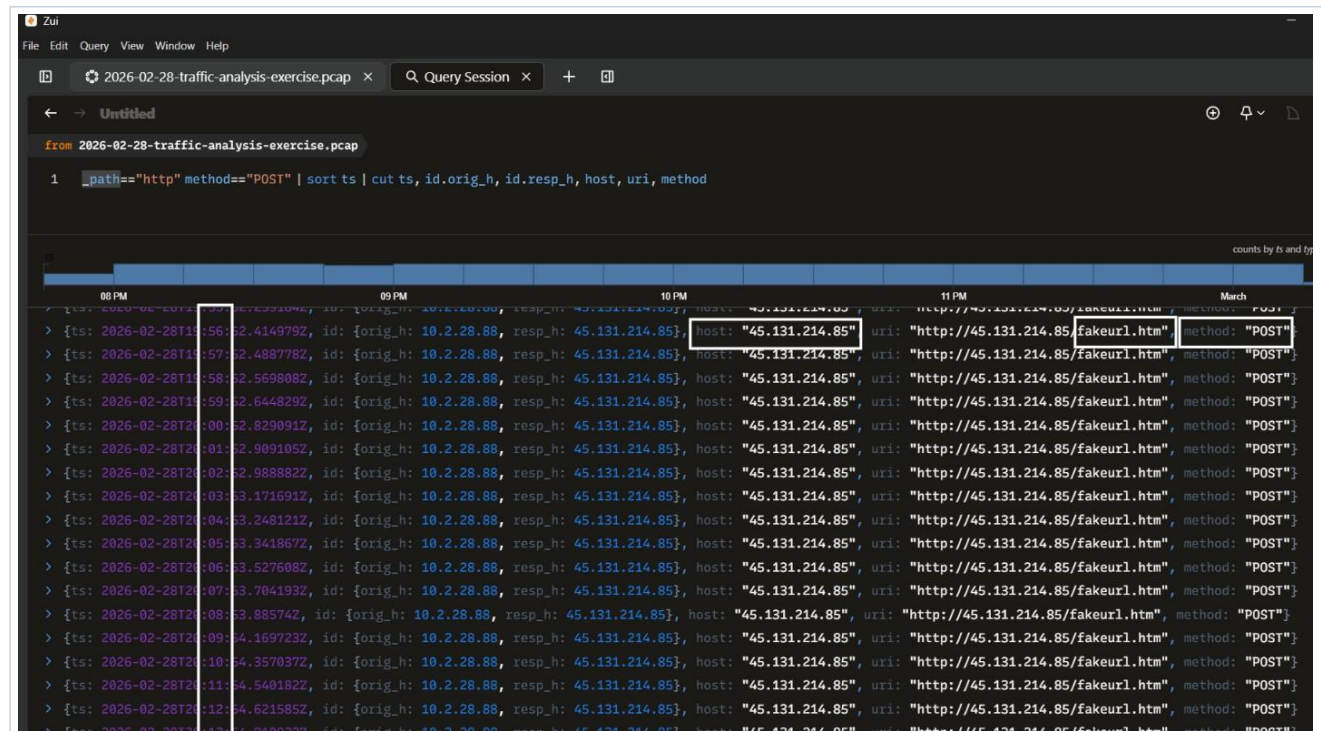


Figure 3. Zui / Zeek query of HTTP POST requests: one POST per minute from 10.2.28.88 to 45.131.214[.]85/fakeurl[.]htm.

### 4.2 Session and Volume Analysis

The Suricata logs allow the session to be measured rather than estimated.

| Measure                | Result                                                                | What it shows                                            |
|------------------------|-----------------------------------------------------------------------|----------------------------------------------------------|
| Alerts / HTTP requests | 264, all on one TCP session (10.2.28.88:51912 to 45.131.214[.]85:443) | A single long-lived connection, not repeated reconnects. |

| Measure       | Result                                                                                                                          | What it shows                                                                      |
|---------------|---------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------|
| Beacon timing | 261 beacons from 19:55:52.239 to 00:16:28.527; mean interval <b>60.14 s</b> , range 60.07 to 60.28 s, standard deviation 0.07 s | Machine-generated; no human or random jitter at all.                               |
| Request size  | First four bodies 22, 244, 76 and 77 bytes (session set-up); every later body <b>exactly 36 bytes</b> (260 requests)            | A fixed-size keep-alive; no variation that would suggest tasking or file transfer. |
| Total volume  | 78,539 bytes out and 17,020 bytes in (about 93 KB) over 4 h 20 min                                                              | Far too small for screen streaming or bulk exfiltration over this channel.         |
| Session end   | Flow state <i>established</i> ; closed by capture shutdown                                                                      | The C2 session was still live at the end of the data.                              |

**Interpretation.** The pattern matches a dormant or idle RAT maintaining its link while waiting for operator instructions. Because the content after `CMD=ENCD` is encrypted, the capture cannot show whether commands were issued, but it does bound the traffic carried by this channel.

### 4.3 Protocol Anomaly Analysis

No single indicator below proves malicious intent on its own. Together they match RAT behaviour and are very unlikely to be legitimate administration traffic.

| Observation                                                                                           | Why it indicates RAT / C2 behaviour                                                                                                                                                                                                                    |
|-------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Plain-text HTTP on TCP/443                                                                            | Port 443 is expected to carry TLS. Cleartext HTTP there evades port-based filters and lazy inspection that equate 443 with HTTPS, and it is a mismatch that application-layer detection can catch.                                                     |
| POST requests to a static .html page                                                                  | Static pages are fetched with GET. Posting data to one means the page is only a decoy path and something else processes the request, typical of C2 endpoints disguised as web content.                                                                 |
| Fixed 60-second interval, 0.07 s deviation                                                            | Human browsing is irregular. A metronomic cadence for hours is a machine-driven heartbeat asking whether the server has a task.                                                                                                                        |
| Rare domain resolved immediately before connecting                                                    | The client looked up <code>vadusa[.]xyz</code> once and connected within milliseconds, yet sends the raw IP as the Host header. The <code>.xyz</code> domain is not part of the normal Microsoft, Adobe or Windows Update traffic seen from this host. |
| User-Agent <code>NetSupport Manager/1.3</code> and server banner <code>NetSupport Gateway/1.92</code> | Both ends speak the NetSupport remote-control protocol. A managed fleet would use an internal, sanctioned gateway; here the gateway is an external address in hosting-provider space.                                                                  |
| Command vocabulary ( <code>CMD=POLL</code> , <code>CMD=ENCD</code> , <code>ES=1</code> )              | <b>POLL</b> is the check-in for tasking; <b>ENCD</b> with <b>ES=1</b> means the session moved to encrypted data, so the operator's commands are no longer readable on the wire.                                                                        |

**Conclusion.** The host is performing automated C2 beaconing to a NetSupport gateway under attacker control. The NetSupport software itself is lawful; the context (external hosting address, rare domain, decoy URI, cleartext HTTP on 443, fixed heartbeat, malicious reputation) is what makes this a RAT.

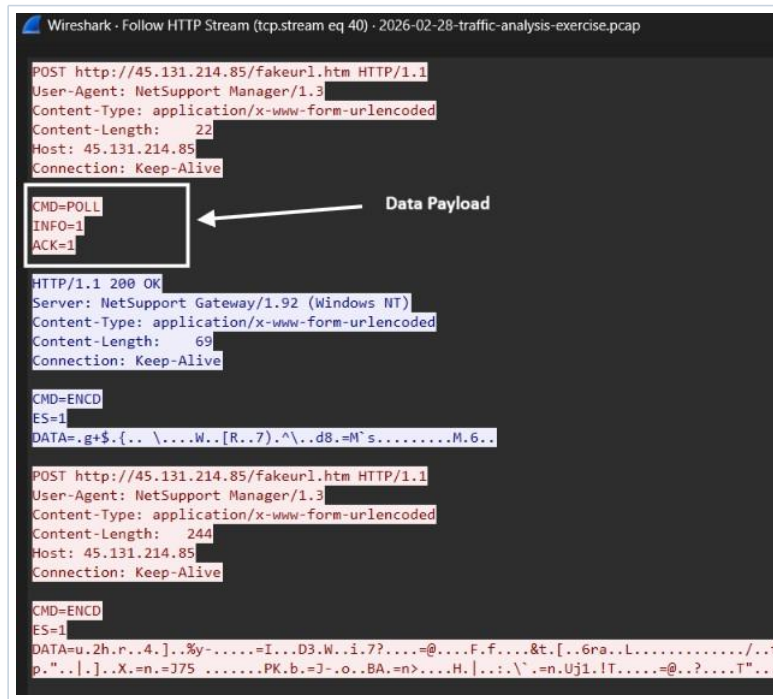


Figure 4. Wireshark Follow HTTP Stream: request with CMD = P O L L (boxed), the 200 OK from NetSupport Gateway/1.92, then encrypted CMD = E N C D exchanges.

#### 4.4 Threat Intelligence Matching

| Source                          | Finding                                                                                                                               | Assessment                                                                              |
|---------------------------------|---------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------|
| VirusTotal (IP reputation)      | 8 security vendors flag 45.131.214[.]85 as malicious: alphaMountain.ai, BitDefender, Dr.Web, Fortinet, G-Data, Lionic, Sophos, VIPRE. | Corroborates malicious infrastructure.                                                  |
| VirusTotal (community comments) | Threat type botnet_cc, confidence 100%, country Netherlands.                                                                          | Infrastructure already verified by analysts and platforms as C2.                        |
| VirusTotal (relations)          | Two files communicate with this IP (SHA-256 in Appendix 6.1).                                                                         | Additional samples to hunt for; not extracted from this capture.                        |
| AbuseIPDB                       | ISP MHost LLC (hosting provider), country Germany, no user reports yet.                                                               | Hosting-provider space fits disposable C2; no reports means the IP is not widely known. |
| Domain vadusa[.]xyz             | Not yet looked up (reputation, registration date, registrar, other IPs).                                                              | <b>Open action:</b> query VirusTotal and WHOIS and add the result here.                 |

The behaviour seen in the capture (NetSupport protocol, 60-second POST beacon, C2 on a hosting-provider IP) agrees with the reputation data, so the two lines of evidence reinforce each other.

#### 4.5 Detection Validation (Suricata Replay)

Rule SID 1000001 was run offline against the capture and the resulting logs were audited.

| Check           | Result                                                                                                                                 |
|-----------------|----------------------------------------------------------------------------------------------------------------------------------------|
| True positives  | 264 of 264 C2 HTTP transactions raised an alert (100% of the C2 requests in eve.json).                                                 |
| False positives | 0. The other 44 HTTP transactions in the capture (Windows Update, BITS, OSCP, connectivity check, Adobe, Edge) raised no alert.        |
| Alert detail    | All alerts are SID 1000001, classification <i>A Network Trojan was detected</i> , severity 1, 10.2.28.88:51912 to 45.131.214[.]85:443. |

| Check             | Result                                                                                                          |
|-------------------|-----------------------------------------------------------------------------------------------------------------|
| Action            | <i>allowed</i> on every alert: the replay ran in IDS mode, so no packet was blocked.                            |
| Port independence | The rule uses <code>alert http</code> (protocol-based), so it fired on port 443 as well as it would on port 80. |

## 4.6 Active Prevention and Automated Mitigation

Moved from passive detection (IDS) to active prevention. Two controls were authored; both are described in Appendices 6.2 and 6.4.

| Control                                                                       | What it does                                                                                                                                                                |
|-------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Suricata IPS rule</b><br><code>drop http ...</code><br>SID 1000003         | Same match as SID 1000001 (POST to <code>/fakeurl.htm</code> ) but with the <code>drop</code> action, so the beacon request is discarded before it reaches the C2 server.   |
| <b>Suricata IPS rule</b><br><code>drop http ...</code><br>SID 1000004         | Stops the NetSupport Remote Access Trojan (RAT) from communicating with its server, even if the malicious link or web address changes.                                      |
| <b>Suricata IPS rule</b><br><code>drop http ...</code><br>SID 1000005         | Blocks attackers attempting to bypass firewalls using non-standard ports.                                                                                                   |
| <b>Suricata IPS rule</b><br><code>reject dns .....</code><br>SID 1000006      | Prevents an infected computer from ever finding the IP address of the attacker's Command and Control (C2) server.                                                           |
| <b>PowerShell firewall script</b><br><code>block_c2_infrastructure.ps1</code> | Creates inbound and outbound Windows Defender Firewall rules that block all protocols to and from 45.131.214[.]85 within milliseconds, without waiting for a manual change. |

**Recommended rollout for the IPS rule:** deploy SID 1000003 in alert-only mode first, confirm it matches only the C2 traffic, then enable enforcement. A fail-open design is advisable so that a sensor fault cannot cut legitimate traffic.

## 4.7 Limitations and Open Questions

- **Initial access vector is unknown.** All 44 non-C2 HTTP transactions go to Microsoft, Adobe, DigiCert or Windows Update endpoints, and the other web traffic is TLS to Microsoft and similar services, so no payload download is visible. The C2 session began about 42 seconds after capture start, right after the host contacted `www.fmcsa.dot.gov` (about 0.3 s earlier). This is a **lead, not a finding**: check proxy, browser and endpoint history for that site, downloads and e-mail around 19:55 UTC.
- **Encrypted C2 content.** After `CMD=ENCD` the session cannot be read. The low volume suggests no bulk theft over this channel in the capture window, but attacker actions cannot be confirmed or excluded.
- **Network-only evidence.** No endpoint telemetry, memory or disk data was available; persistence mechanisms are therefore unconfirmed.
- **Single-host scope.** Within the capture only 10.2.28.88 is involved, but other hosts outside it have not been checked against the indicators.
- **File types.** The file-type (magic) field is empty in the Suricata logs, so the types of transferred objects were not identified.

## 5. Containment, Eradication & Remediation

Actions below are **recommendations** derived from the analysis. They are ordered by urgency.

## 5.1 Immediate Containment

| # | Action               | Details                                                                                                                                                                                                                                                                                                                         | When        |
|---|----------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------|
| 1 | Isolate asset        | Disconnect DESKTOP-TEYQ2NR (10.2.28.88) from the network immediately: disable the NIC, port-isolate the switch port or use EDR network containment. This stops the C2 channel and prevents lateral movement. Keep the machine powered on until a memory image is captured, then shut it down.                                   | Immediately |
| 2 | Revoke credentials   | Reset the Active Directory password for user <b>brolf</b> and terminate all active Kerberos ticket-granting sessions: disable the account, force log-off of active sessions and confirm no valid tickets remain (default TGT lifetime is 10 hours unless policy differs). Review any other account that logged on to the host.  | Immediately |
| 3 | Block infrastructure | Add <b>45.131.214[.]85</b> (all ports; 443 observed) to the perimeter firewall and web-proxy blocklists in both directions, and sinkhole or block the domain <b>vadusa[.]xyz</b> in DNS (RPZ or DNS firewall). Log hits to reveal other infected hosts. The host-level script in Appendix 6.4 can be pushed to other endpoints. | Immediately |
| 4 | Preserve evidence    | Retain the PCAP, Zeek logs, Suricata <code>eve.json</code> and <code>fast.log</code> , the memory image and file hashes, and record chain of custody before any remediation alters the host.                                                                                                                                    | Immediately |
| 5 | Scope the incident   | Search DNS logs for queries to <b>vadusa[.]xyz</b> (this catches hosts even if the IP changes), and proxy, firewall, Zeek and EDR data for <b>45.131.214[.]85</b> and the <b>NetSupport Manager/1.3 User-Agent</b> ; check other endpoints for an unauthorised NetSupport client.                                               | Within 24 h |

**Note on host-level blocking.** A firewall rule on the infected machine is only a stopgap: malware with administrator rights can remove it. Network isolation (action 1) remains the primary containment; the script is most valuable on *other* endpoints.

## 5.2 Eradication

- Create a **forensic disk image** of DESKTOP-TEYQ2NR and analyse the image offline; carve out and identify the persistence mechanisms: **Registry Run keys**, **Scheduled Tasks** and **malicious services** that launch the NetSupport RAT client.
- Hunting hints from public NetSupport RAT reporting (not observed in this capture): `client32.exe`, `client32.ini` and `NSM.lic` in user-writable folders.
- Determine the **initial access vector** (phishing attachment or link, malicious download, compromised web site) from e-mail gateway, proxy and endpoint logs, starting with the activity around 19:55 UTC described in Section 4.6.
- Search the two VirusTotal-related SHA-256 hashes (Appendix 6.1) across the estate.

## 5.3 Recovery

- **Re-image the host** from a known-good baseline before it returns to production; do not clean it in place.
- Re-join the domain with a fresh computer-account password and restore user data only from verified-clean sources, scanned before restoration.
- Re-enable account brolf only with new credentials (and MFA where available) and brief the user on the incident.
- Return the host to service only after the re-image is verified and the EDR agent is healthy, then apply heightened monitoring for any traffic to the Appendix 6.1 indicators and for unusual Kerberos activity from the host and user.

## 5.4 Lessons Learned & Long-Term Defenses

| Control                         | Recommendation                                                                                                                                                                                                              |
|---------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>IDS signature deployment</b> | Deploy custom Suricata rule <b>SID 1000001</b> across all enterprise network taps and sensors and forward its alerts to the SIEM at high priority. Validation showed 264 of 264 true positives and no false positives.      |
| <b>Egress filtering</b>         | Block direct outbound HTTP/HTTPS traffic to IP addresses that bypasses the corporate web proxies; require proxy use for all web egress. Do not treat port 443 as proof of encrypted traffic: use protocol-aware inspection. |
| Detection depth                 | Authored multi-layer detection rules (SID 1000004-1000006) to cover protocol anomalies, hardcoded application headers, and DNS pre-beaconing queries to survive C2 URI changes.                                             |
| DNS controls                    | Log and filter DNS centrally; sinkhole known-bad domains and alert on first-seen or newly registered domains.                                                                                                               |
| Application control             | Allow-list approved remote-administration tools; alert on NetSupport client installation or execution outside IT-managed systems.                                                                                           |
| Endpoint and identity           | Ensure EDR coverage with persistence monitoring (Run keys, tasks, services); monitor Kerberos anomalies; apply least privilege and MFA.                                                                                     |
| Threat intelligence             | Load the Appendix 6.1 indicators into the SIEM, firewall, proxy and DNS filter, and retro-hunt against historical logs.                                                                                                     |
| People and process              | Update the IR playbook with this scenario and run phishing-awareness training, since the delivery method is still unidentified.                                                                                             |

## 6. Appendix

### 6.1 Complete Defanged IOC Table

Copy-paste ready. Refang ([.] to ., h x x p to h t t p) before loading into enforcement tools.

| Type            | Indicator                                | Context                                                  |
|-----------------|------------------------------------------|----------------------------------------------------------|
| Domain          | vadusa[.]xyz                             | C2 domain; resolved to the C2 IP at connection start     |
| IPv4            | 45.131.214[.]85                          | C2 server; 8 vendors flag as malicious; <i>botnet_cc</i> |
| DNS record      | vadusa[.]xyz A 45.131.214[.]85 (TTL 300) | Answer returned via 10.2.28.2                            |
| Port / protocol | 443/tcp (plain-text HTTP)                | C2 channel; no TLS                                       |
| URL             | hxxp://45.131.214[.]85/fakeurl[.]htm     | Beacon endpoint (port 443)                               |
| URI path        | /fakeurl[.]htm                           | Decoy static path receiving POST                         |
| Host header     | 45.131.214[.]85                          | Raw IP used as Host value                                |
| HTTP method     | POST                                     | Every 60 s; fixed 36-byte body                           |
| User-Agent      | NetSupport Manager/1.3                   | Client side of NetSupport protocol                       |
| Server banner   | NetSupport Gateway/1.92 (Windows NT)     | C2 response header                                       |
| Payload string  | CMD=POLL&INFO=1&ACK=1                    | Plaintext check-in                                       |
| Payload string  | CMD=ENCD&ES=1                            | Encrypted session marker                                 |

| Type      | Indicator                                                        | Context                                                                          |
|-----------|------------------------------------------------------------------|----------------------------------------------------------------------------------|
| SHA-256   | 712c7e845543e6ddd07f724b6f9a9a0e2c84fdf6d8956fdd2bef94775b2ef707 | File communicating with the C2 IP (VirusTotal relation; not extracted from PCAP) |
| SHA-256   | c9e5bb7a368280d771edcfdb33717a3130560d2bb71773ab1aaffe0eb585fd2c | File communicating with the C2 IP (VirusTotal relation; not extracted from PCAP) |
| Detection | sid:1000001 / sid:1000003                                        | Suricata alert rule / IPS drop rule                                              |

**Affected assets (not indicators of compromise):** host DESKTOP-TEYQ2NR, 10.2.28.88, MAC 00:19:d1:b2:4d:ad, domain EASYAS123, user brolf (see Section 3).

## 6.2 Detection and Prevention Signatures (Suricata)

Stored in `rules/custom_detection.rules` (one rule per line).

### SID 1000001: detection (alert)

```
alert http $HOME_NET any -> $EXTERNAL_NET any \
(msg:"CUSTOM DETECT Malicious C2 HTTP POST Request to Pseudo-Static URI (/fakeurl.htm)"; \
flow:established,to_server; \
http.method; content:"POST"; \
http.uri; content:"/fakeurl.htm"; fast_pattern; \
classtype:trojan-activity; sid:1000001; rev:1;)
```

### SID 1000003: prevention (drop, inline IPS mode only)

```
drop http $HOME_NET any -> $EXTERNAL_NET any \
(msg:"CUSTOM IPS DROP Malicious C2 Beaconing & Terminate Session (/fakeurl.htm)"; \
flow:established,to_server; \
http.method; content:"POST"; \
http.uri; content:"/fakeurl.htm"; fast_pattern; \
classtype:trojan-activity; sid:1000003; rev:1;)
```

### SID 1000004: prevention (drop, NetSupport RAT User-Agent)

```
drop http $HOME_NET any -> $EXTERNAL_NET any
(msg:"CUSTOM IPS DROP NetSupport RAT Outbound User-Agent";
flow:established,to_server;
http.user_agent; content:"NetSupport Manager/1.3";
fast_pattern; classtype:trojan-activity; sid:1000004; rev:2;)
```

### SID 1000005: prevention (drop, Cleartext HTTP over Port 443)

```
drop http $HOME_NET any -> $EXTERNAL_NET 443
(msg:"CUSTOM IPS DROP Cleartext HTTP Traffic over Non-Standard Port 443";
flow:established,to_server;
classtype:bad-unknown; sid:1000005; rev:2;)
```

### SID 1000006: prevention (drop, C2 Domain DNS Query)

```
reject dns $HOME_NET any -> $EXTERNAL_NET 53
(msg:"CUSTOM IPS REJECT DNS Query for NetSupport C2 (vadusa.xyz)";
dns.query; content:"vadusa.xyz"; nocase;
fast_pattern; classtype:trojan-activity; sid:1000006; rev:2;)
```

### Validation command (offline replay):

```
& "C:\Program Files\Suricata\suricata.exe" -c "C:\Program Files\Suricata\suricata.yaml" \
-s rules\custom_detection.rules -r sample_infection.pcap -l logs
```

Results were audited in `logs\fast.log` and `logs\eve.json` (Section 4.5). Screenshots are in the repository under `screenshots/`.

### 6.3 Evidence and Tooling

| Item                                                       | Use in this investigation                                           |
|------------------------------------------------------------|---------------------------------------------------------------------|
| Wireshark                                                  | Deep packet inspection, display filters, HTTP stream reconstruction |
| NetworkMiner                                               | Passive forensics: host, credential and session cross-validation    |
| Zui / Brim (Zeek)                                          | Indexed Zeek logs: HTTP triage and beaconing detection              |
| Suricata ( <code>eve.json</code> , <code>fast.log</code> ) | IDS engine; alert audit, flow, DNS and session statistics           |
| Suricata IPS (NFQ / WinDivert)                             | Inline mode required for the <code>drop</code> rule                 |
| PowerShell, Windows Defender Firewall                      | Automated host-level C2 block                                       |
| VirusTotal, AbuseIPDB                                      | OSINT reputation and relations for the C2 IP                        |
| Malware-Traffic-Analysis.net                               | Source of the training capture (2026-02-28 exercise)                |
| NIST SP 800-61; SANS PICERL                                | Incident-handling frameworks used to structure this report          |

## 6.4 Automated Host Firewall Block Script (PowerShell)

File `scripts/block_c2_infrastructure.ps1`. Run as Administrator. The version below checks for each rule by its exact name, so repeated runs do not create duplicates.

```
# Define Malicious C2 Target
$C2_IP = "45.131.214.85"
$RuleName = "SOC-IR-BLOCK-C2-NetSupport-$C2_IP"
Write-Host "[*] Starting Incident Response Containment Action..." -ForegroundColor Yellow
# Check if rule already exists
$ExistingRule = Get-NetFirewallRule -DisplayName $RuleName -ErrorAction SilentlyContinue
if ($ExistingRule) {
    Write-Host "[!] Firewall rule for $C2_IP already exists. Containment active." -ForegroundColor Green
} else {
    Write-Host "[+] Creating Outbound & Inbound Block Rules for C2 IP: $C2_IP" -ForegroundColor Red
    # Block Outbound Traffic (Stops victim from sending beaconing packets)
    New-NetFirewallRule -DisplayName "$RuleName-Outbound" `
        -Direction Outbound `
        -RemoteAddress $C2_IP `
        -Action Block `
        -Protocol Any `
        -Enabled True `
        -Description "Automated SOC Block: NetSupport RAT C2 Beaconing"
    # Block Inbound Traffic (Stops C2 from sending remote commands)
    New-NetFirewallRule -DisplayName "$RuleName-Inbound" `
        -Direction Inbound `
        -RemoteAddress $C2_IP `
        -Action Block `
        -Protocol Any `
        -Enabled True `
        -Description "Automated SOC Block: NetSupport RAT C2 Beaconing"
    Write-Host "[SUCCESS] Host firewall rules applied successfully! Traffic to $C2_IP is fully isolated." -ForegroundColor Green
}
```

**Verification:** `Get-NetFirewallRule -DisplayName "SOC-IR-BLOCK-C2-NetSupport-45.131.214.85-Outbound" |`

`Get-NetFirewallAddressFilter` should list the remote address 45.131.214.85, and `Test-NetConnection 45.131.214.85`

`-Port 443` should fail.